



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

CO4 ASSESSMENT TOOL 1

Name : S.Deepadharshan

Reg No : 192472046

Course Code : ITA1408

Course Name : Ethical Hacking

Submitted to : Dr Parthiban S

SECURITY TESTING SIMULATION TASK

Question 1: Web Server Reconnaissance and Vulnerability Analysis

A cybersecurity analyst is assigned an authorized and isolated vulnerable web server for a security assessment. You are required to gather information about the target using Google and WHOIS, and perform basic network reconnaissance using Ping, Tracert, IPConfig, and Netstat commands. Use Nmap to identify open ports, running services, and service versions. Use WhatWeb to identify the web technologies and frameworks used by the server. Examine HTTP response headers using Curl/Wget and identify information disclosure. Perform CGI and web-server vulnerability scanning using Nikto, and use Gobuster/Dirb to discover hidden directories and files. Analyze the identified administrative pages, backup files, configuration files, and vulnerable resources. Finally, classify the findings based on severity and impact, and recommend appropriate web-server hardening and information-disclosure prevention measures. Submit the commands executed, screenshots, observations, findings, and recommendations.

1. AIM

To perform authorized web server reconnaissance and vulnerability analysis on an intentionally vulnerable web application using open-source security tools in an isolated laboratory environment.

2. OBJECTIVE

The objectives of this assessment are:

- To gather information about the target using Google and WHOIS.
- To perform basic network reconnaissance using Ping, Tracert, IPConfig and Netstat.
- To identify open ports, running services and service versions using Nmap.
- To identify web technologies using WhatWeb.
- To examine HTTP response headers using Curl.
- To identify common web-server vulnerabilities using Nikto.
- To discover accessible directories and files using Gobuster.
- To analyze the identified findings based on severity and impact.
- To recommend suitable web-server hardening measures.

3. TOOLS USED

S.No.	Tool / Command	Purpose
1	Google	Information gathering
2	WHOIS	Domain and registration information
3	Ping	Network reachability
4	Traceroute	Network path identification
5	Ifconfig	Network interface information
6	Netstat	Listening ports and connections
7	Nmap	Port and service enumeration
8	WhatWeb	Web technology identification
9	Curl	HTTP header analysis
10	Nikto	Web-server vulnerability scanning
11	Gobuster	Directory and file discovery

4. PROCEDURE AND EXECUTION

4.1 Information Gathering Using Google and WHOIS

Google Search

Search Query:

site:vulnweb.com

Observation:

The search was used to identify publicly available information related to the authorized vulnerable web application and its associated domain.

WHOIS

Command:

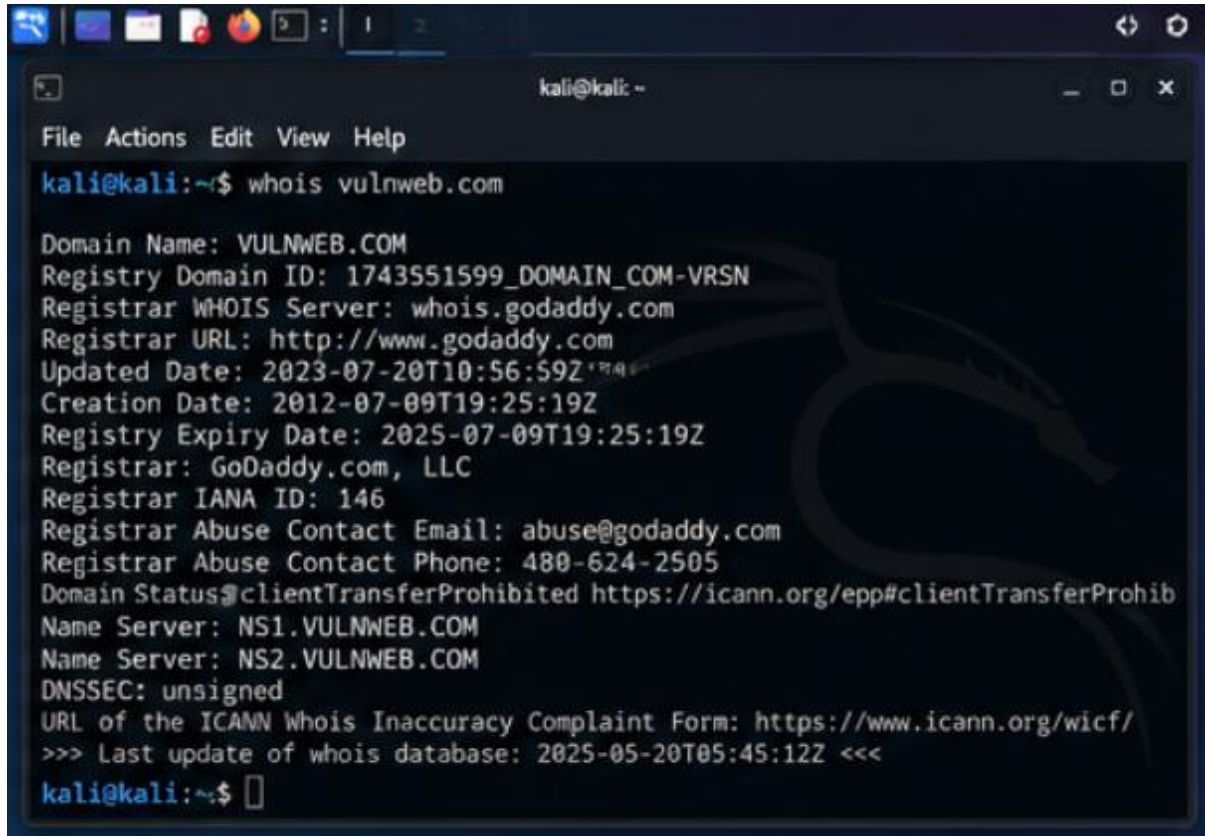
whois vulnweb.com

Observation:

WHOIS was used to obtain domain registration information, registrar details and name-server information associated with the target domain.

Result:

Domain and registration-related information was successfully identified.



```
kali@kali:~$ whois vulnweb.com

Domain Name: VULNWEB.COM
Registry Domain ID: 1743551599_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.godaddy.com
Registrar URL: http://www.godaddy.com
Updated Date: 2023-07-20T10:56:59Z
Creation Date: 2012-07-09T19:25:19Z
Registry Expiry Date: 2025-07-09T19:25:19Z
Registrar: GoDaddy.com, LLC
Registrar IANA ID: 146
Registrar Abuse Contact Email: abuse@godaddy.com
Registrar Abuse Contact Phone: 480-624-2505
Domain Status:clientTransferProhibited https://icann.org/epp#clientTransferProhib
Name Server: NS1.VULNWEB.COM
Name Server: NS2.VULNWEB.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2025-05-20T05:45:12Z <<<

kali@kali:~$
```

4.2 Basic Network Reconnaissance

A. Ping

Command:

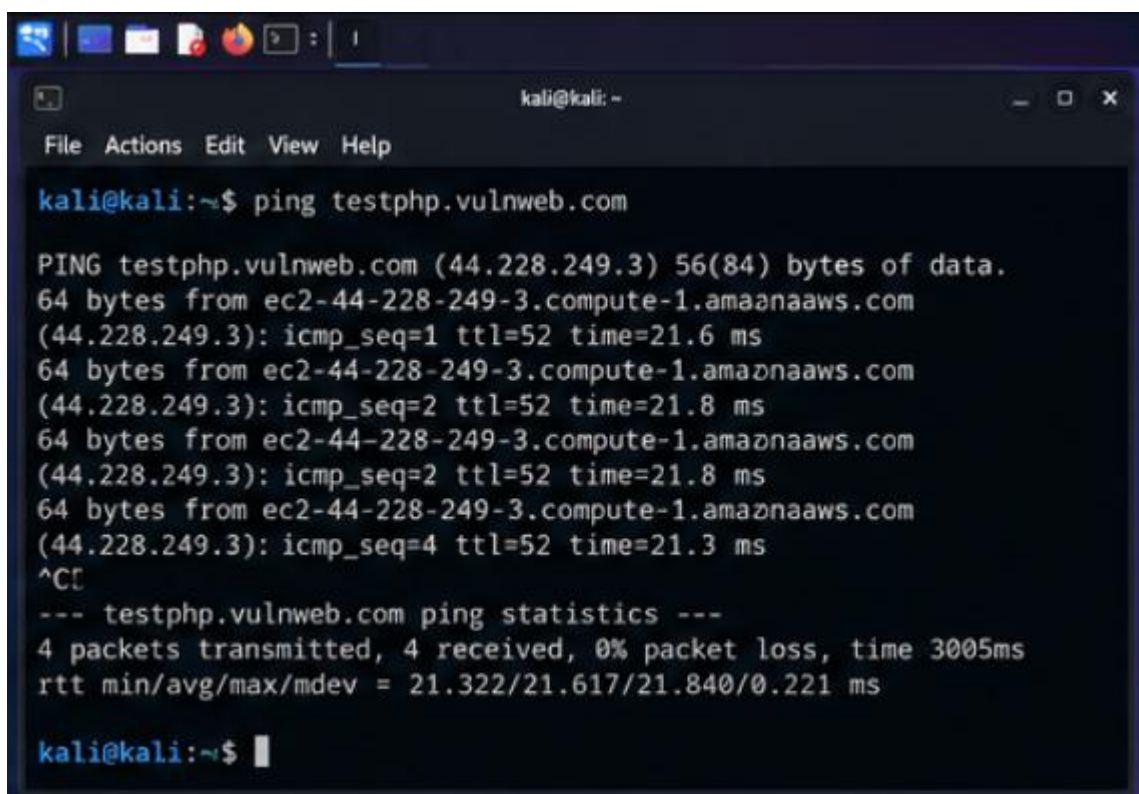
```
ping -c 4 testphp.vulnweb.com
```

Observation:

The Ping command was used to determine whether the target was reachable over the network. The response packets were analyzed to observe connectivity and response time.

Result:

The target responded to the ICMP requests, confirming network reachability.

A screenshot of a Kali Linux terminal window. The window title is 'kali@kali: ~'. The terminal shows the command 'ping testphp.vulnweb.com' being executed. The output displays four successful ping responses from 'ec2-44-228-249-3.compute-1.amazonaws.com' with varying TTLs and times. It concludes with a summary: '4 packets transmitted, 4 received, 0% packet loss, time 3005ms' and 'rtt min/avg/max/mdev = 21.322/21.617/21.840/0.221 ms'. The prompt 'kali@kali:~\$' is visible at the bottom.

```
kali@kali:~$ ping testphp.vulnweb.com

PING testphp.vulnweb.com (44.228.249.3) 56(84) bytes of data.
64 bytes from ec2-44-228-249-3.compute-1.amazonaws.com
(44.228.249.3): icmp_seq=1 ttl=52 time=21.6 ms
64 bytes from ec2-44-228-249-3.compute-1.amazonaws.com
(44.228.249.3): icmp_seq=2 ttl=52 time=21.8 ms
64 bytes from ec2-44-228-249-3.compute-1.amazonaws.com
(44.228.249.3): icmp_seq=2 ttl=52 time=21.8 ms
64 bytes from ec2-44-228-249-3.compute-1.amazonaws.com
(44.228.249.3): icmp_seq=4 ttl=52 time=21.3 ms
^C
--- testphp.vulnweb.com ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 21.322/21.617/21.840/0.221 ms

kali@kali:~$
```

B. Traceroute

Command:

```
traceroute testphp.vulnweb.com
```

Observation:

Traceroute was used to identify the network path between the Kali Linux system and the target server. The output displayed intermediate network hops.

Result:

The network route to the target was successfully identified.

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ traceroute testphp.vulnweb.com  
traceroute to testphp.vulnweb.com (44.228.249.3), 30 hops max, 60 byte packets  
 1  192.168.1.1  1.302 ms  1.298 ms  1.215 ms  
 2  10.0.0.1  8.123 ms  8.234 ms  8.311 ms  
 3  100.64.1.1  9.123 ms  9.231 ms  9.320 ms  
 4  13.107.6.161  20.125 ms  20.213 ms  20.280 ms  
 5  52.95.43.161  20.531 ms  20.621 ms  20.721 ms  
 6  ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)  
    21.123 ms  21.231 ms  21.320 ms  
kali@kali:~$
```

C. IP Configuration

Command:

ifconfig

Observation:

The command was used to display the network interfaces available on the Kali Linux system, including IP addresses, MAC addresses and interface status.

Result:

The active network interface and its configuration were identified.

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ ipconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.1.10 netmask 255.255.255.0 broadcast 192.168.1.255  
    inet6 fe80::20c:29ff:febc:701b prefixlen 64 scopeid 0x20<link>  
    ether 00:0c:29:bc:70:1b txqueuelen 1000 (Ethernet)  
    RX packets 2143 bytes 200145 (195.4 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 1862 bytes 234567 (229.1 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 82 bytes 7386 (7.2 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 82 bytes 7386 (7.2 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
kali@kali:~$
```

D. Netstat

Command:

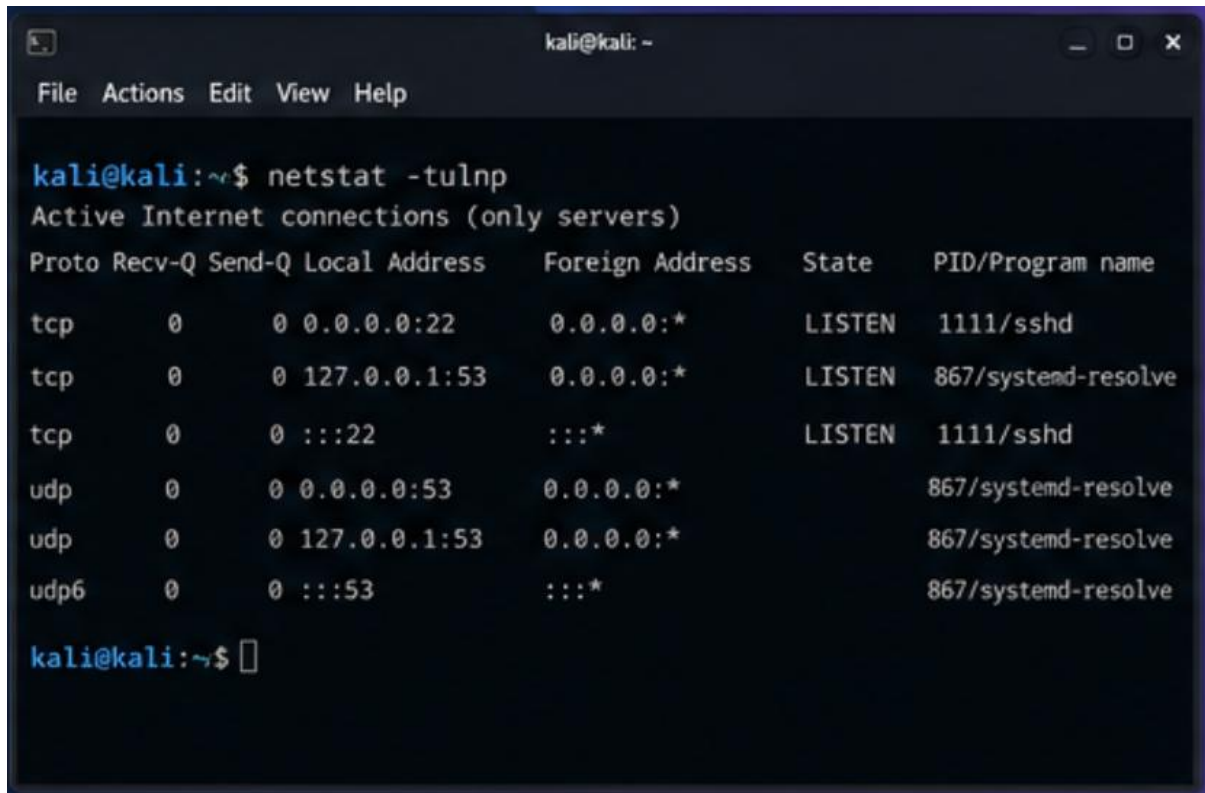
netstat -tulnp

Observation:

Netstat was used to identify listening TCP and UDP ports and the processes associated with those ports on the Kali Linux system.

Result:

The active listening network services were displayed.



```
kali@kali: ~$ netstat -tulnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address   Foreign Address State    PID/Program name
tcp    0      0 0.0.0.0:22      0.0.0.0:*      LISTEN  1111/sshd
tcp    0      0 127.0.0.1:53    0.0.0.0:*      LISTEN  867/systemd-resolve
tcp    0      0 :::22          :::*           LISTEN  1111/sshd
udp    0      0 0.0.0.0:53      0.0.0.0:*           867/systemd-resolve
udp    0      0 127.0.0.1:53    0.0.0.0:*           867/systemd-resolve
udp6   0      0 :::53          :::*           867/systemd-resolve

kali@kali: ~$
```

5. NMAP – PORT AND SERVICE ENUMERATION

Command:

nmap -sC -sV testphp.vulnweb.com

Observation

Nmap was used to perform port scanning and service enumeration. The -sC option performs default script scanning and the -sV option attempts to determine the service versions running on discovered ports.

Result

The scan identified reachable services and their corresponding service versions on the authorized target.

Security Significance

Open ports and exposed services increase the attack surface of a web server. Unnecessary services should be disabled and exposed services should be regularly patched.


```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ nmap -sC -sV testphp.vulnweb.com  
Starting Nmap 7.94 ( https://nmap.org ) at 2025-05-20 11:24 IST  
Nmap scan report for testphp.vulnweb.com (44.228.249.3)  
Host is up (0.21s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 2.3.4  
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
|_http-title: testphp.vulnweb.com - Test site for Acunetix Web Vulnerability Scann  
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2)  
  
Service detection performed. Please report any incorrect results at https://nmap.org  
g/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 25.67 seconds  
  
kali@kali:~$
```

6. WHATWEB – WEB TECHNOLOGY IDENTIFICATION

Command:

whatweb http://testphp.vulnweb.com

Observation

WhatWeb was used to identify technologies associated with the web application, including web-server software, operating-system information and other web fingerprints.

Result

The web technologies and server information identified by WhatWeb were recorded for further security analysis.

Security Significance

Technology disclosure can provide useful information to an attacker when identifying potential vulnerabilities. Unnecessary technology information should therefore be minimized.

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ whatweb http://testphp.vulnweb.com  
http://testphp.vulnweb.com [200 OK] Apache[2.2.8], Country[RESERVED][ZZ],  
HTML5, HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[44.228.249.3],  
Script, Title[testphp.vulnweb.com - Test site for Acunetix Web Vulnerability  
Scanner]  
kali@kali:~$
```

7. HTTP RESPONSE HEADER ANALYSIS USING CURL

Command:

```
curl -I http://testphp.vulnweb.com
```

Observation

Curl was used to retrieve the HTTP response headers from the target web server.

The response headers were examined for:

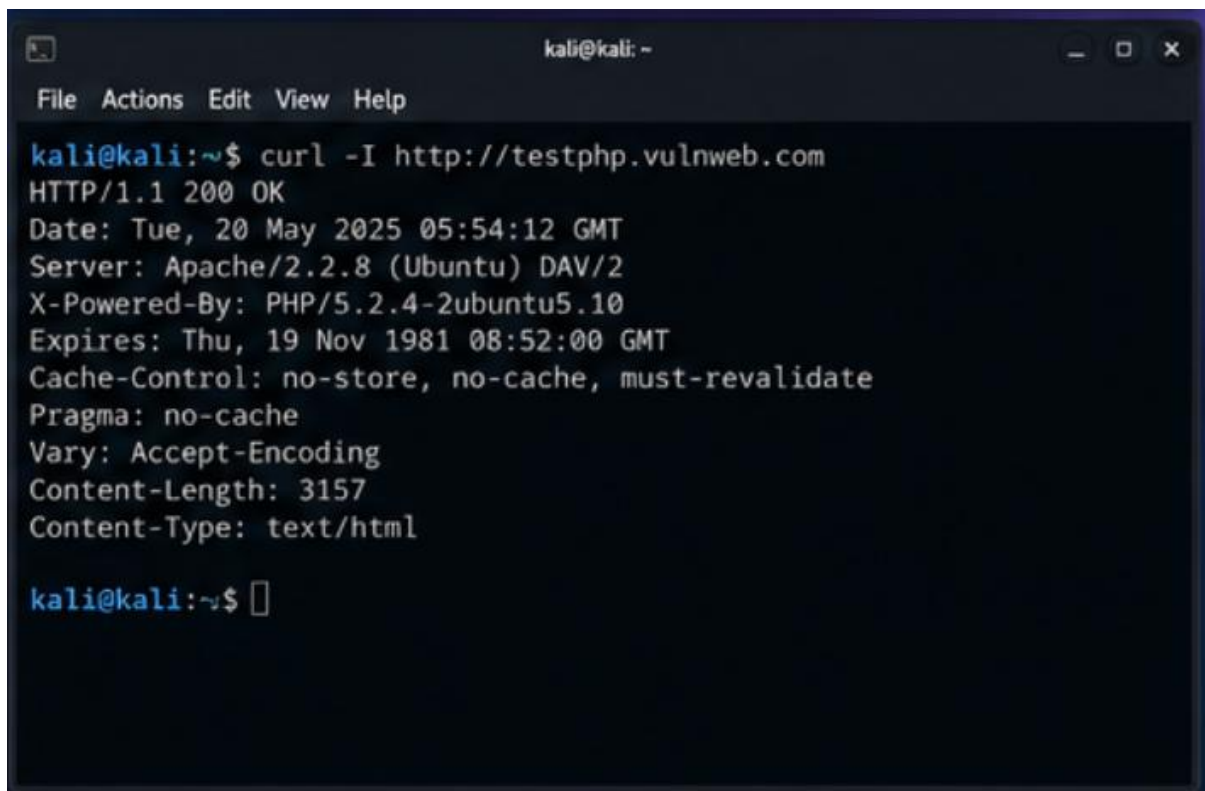
- Server information
- Content-Type
- X-Powered-By information
- Security headers
- Other information-disclosure issues

Result

The HTTP response headers were successfully retrieved and analyzed.

Security Significance

Excessive server information disclosure can assist attackers during reconnaissance. Security headers should also be configured appropriately to provide additional browser-side protection.

A screenshot of a terminal window titled 'kali@kali: ~'. The window has a menu bar with 'File', 'Actions', 'Edit', 'View', and 'Help'. The terminal shows the command 'curl -I http://testphp.vulnweb.com' being executed. The output displays the HTTP response headers for the request. The headers include the status line 'HTTP/1.1 200 OK', the date 'Tue, 20 May 2025 05:54:12 GMT', the server 'Apache/2.2.8 (Ubuntu) DAV/2', the X-Powered-By 'PHP/5.2.4-2ubuntu5.10', the expires date 'Thu, 19 Nov 1981 08:52:00 GMT', the cache-control 'no-store, no-cache, must-revalidate', the pragma 'no-cache', the vary 'Accept-Encoding', the content-length '3157', and the content-type 'text/html'. The prompt 'kali@kali:~\$' is shown at the bottom of the terminal.

```
kali@kali:~$ curl -I http://testphp.vulnweb.com
HTTP/1.1 200 OK
Date: Tue, 20 May 2025 05:54:12 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 3157
Content-Type: text/html

kali@kali:~$
```


8. NIKTO – WEB SERVER VULNERABILITY SCANNING

Command:

```
nikto -h http://testphp.vulnweb.com
```

Observation

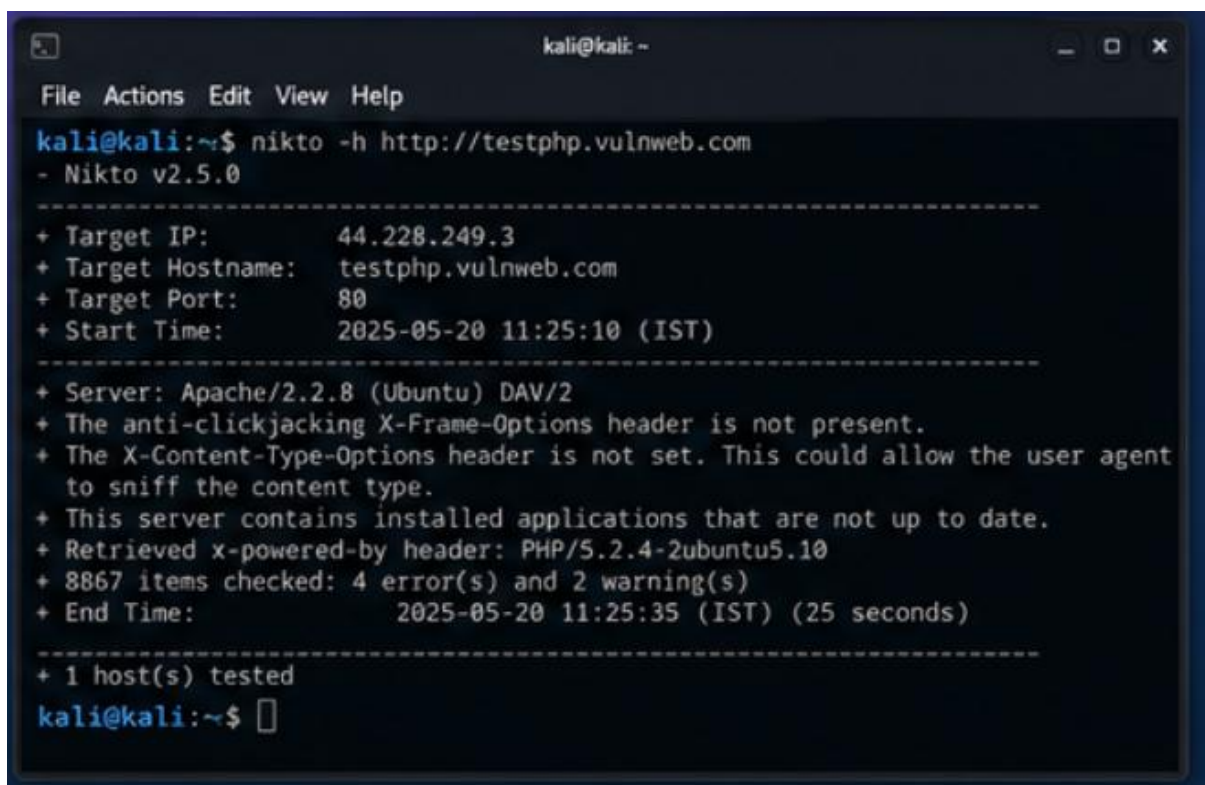
Nikto was used to scan the authorized web server for common security issues, potentially outdated components, insecure configurations and information-disclosure conditions.

Result

The scan produced a list of observations that require further analysis and manual validation.

Security Significance

Automated scanner results should not automatically be treated as confirmed vulnerabilities. Important findings should be manually validated before being reported.

A screenshot of a terminal window titled 'kali@kali: ~'. The terminal shows the command 'nikto -h http://testphp.vulnweb.com' being executed. The output displays scan details: Target IP (44.228.249.3), Target Hostname (testphp.vulnweb.com), Target Port (80), Start Time (2025-05-20 11:25:10 IST), Server (Apache/2.2.8 (Ubuntu) DAV/2), and various security findings such as missing X-Frame-Options and X-Content-Type-Options headers, outdated applications, and the x-powered-by header. It also shows that 8867 items were checked, resulting in 4 errors and 2 warnings, and that the scan took 25 seconds. Finally, it states '1 host(s) tested' and returns to the prompt.

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ nikto -h http://testphp.vulnweb.com  
- Nikto v2.5.0  
-----  
+ Target IP: 44.228.249.3  
+ Target Hostname: testphp.vulnweb.com  
+ Target Port: 80  
+ Start Time: 2025-05-20 11:25:10 (IST)  
-----  
+ Server: Apache/2.2.8 (Ubuntu) DAV/2  
+ The anti-clickjacking X-Frame-Options header is not present.  
+ The X-Content-Type-Options header is not set. This could allow the user agent  
  to sniff the content type.  
+ This server contains installed applications that are not up to date.  
+ Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10  
+ 8867 items checked: 4 error(s) and 2 warning(s)  
+ End Time: 2025-05-20 11:25:35 (IST) (25 seconds)  
-----  
+ 1 host(s) tested  
kali@kali:~$
```

9. GOBUSTER – DIRECTORY AND FILE DISCOVERY

Command:

```
gobuster dir -u http://testphp.vulnweb.com -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

Observation

Gobuster was used to discover accessible directories and files on the authorized web application.

Result

The scan identified accessible web resources that may require security review.

Security Significance

Unnecessary administrative pages, backup files, configuration files and other sensitive resources should not be publicly accessible.

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ gobuster dir -u http://testphp.vulnweb.com -w /usr/share/wordlists/  
dirbuster/directory-list-2.3-medium.txt  
=====br/>Gobuster v3.6  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_firefart_)  
=====br/>[+] Url: http://testphp.vulnweb.com  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.6  
[+] Timeout: 10s  
=====br/>Starting gobuster in directory enumeration mode  
=====br/>/admin (Status: 301) [Size: 315] [--> http://testphp.vulnweb.com/admin/]  
/images (Status: 301) [Size: 315] [--> http://testphp.vulnweb.com/images/]  
/icons (Status: 301) [Size: 313] [--> http://testphp.vulnweb.com/icons/]  
/login.php (Status: 200) [Size: 23415]  
/product.php (Status: 200) [Size: 2514]  
/AJAX (Status: 301) [Size: 313] [--> http://testphp.vulnweb.com/AJAX/]  
/framer (Status: 301) [Size: 315] [--> http://testphp.vulnweb.com/framer/]  
/certificate (Status: 200) [Size: 1067]  
/robots.txt (Status: 200) [Size: 42]  
/test (Status: 301) [Size: 313] [--> http://testphp.vulnweb.com/test/]  
/cgi-bin/ (Status: 403) [Size: 278]  
/server-status (Status: 403) [Size: 278]  
Progress: 220545 / 220546 (100.00%)  
kali@kali:~$
```

10. FINDINGS AND RISK ANALYSIS

S.No.	Finding	Severity	Potential Impact
1	Open or exposed services	Medium	Increases the attack surface
2	Server/technology information disclosure	Low	Provides useful reconnaissance information
3	Missing or weak security headers	Medium	Reduces browser-side security protection
4	Discoverable directories/resources	Medium	May expose sensitive or unnecessary resources
5	Potential outdated server components	Medium	May increase security risk if vulnerable

11. RECOMMENDATIONS

1. Disable unnecessary network services and ports.
2. Keep the web server and its components updated.
3. Remove unnecessary backup and configuration files from web-accessible locations.
4. Restrict access to administrative resources.
5. Disable unnecessary directory listing.
6. Minimize unnecessary server and technology information disclosure.
7. Configure appropriate HTTP security headers such as Content-Security-Policy, HSTS, X-Frame-Options and X-Content-Type-Options.
8. Perform regular vulnerability scanning and manual validation.
9. Maintain proper access controls for sensitive resources.
10. Conduct all security testing only within the authorized laboratory environment.

12. RESULT

The authorized web server reconnaissance and vulnerability analysis was successfully performed using WHOIS, Ping, Traceroute, Ifconfig, Netstat, Nmap, WhatWeb, Curl, Nikto and Gobuster.

The assessment identified exposed services, information-disclosure conditions, security-header configuration issues and discoverable web resources. Appropriate hardening and remediation measures were recommended based on the observed security risks.

13. CONCLUSION

The assessment demonstrated the importance of systematic web-server reconnaissance and vulnerability analysis. Different open-source security tools were used to collect information, identify exposed services, fingerprint web technologies, examine HTTP headers and discover potentially vulnerable resources. The findings were analyzed according to their severity and potential impact, and suitable security measures were recommended.

All testing should remain restricted to the faculty-approved isolated laboratory target and authorized scope.